SICUREZZA · PARTE 2

Regole e processi aziendali

Le regole comuni per proteggere dati, soldi e persone. E cosa fare quando qualcosa va storto.

Per tutti, obbligatorio

Prima: Parte 1, livello 1

25 minuti + domande



12
policy aziendali, in breve

8
playbook: cosa fare se succede

12
guide passo passo per il setup

INTRODUZIONE

Di cosa parliamo oggi

Le regole

Account, email, pagamenti, dispositivi, dati e AI: cosa si fa e cosa no.

I processi

Cosa fare se succede qualcosa, come configurare i dispositivi, cosa cambia quando entri o esci.

Le policy

Le 12 policy aziendali in breve, allineate a ISO 27001 e alla legge sulla protezione dei dati.

Valgono per tutti allo stesso modo, collaboratori esterni compresi. Non servono a controllarti: servono a proteggerti.

IL PUNTO

Le truffe funzionano quando decidi da solo e di fretta.
Con le regole non decidi mai da solo, né di fretta.

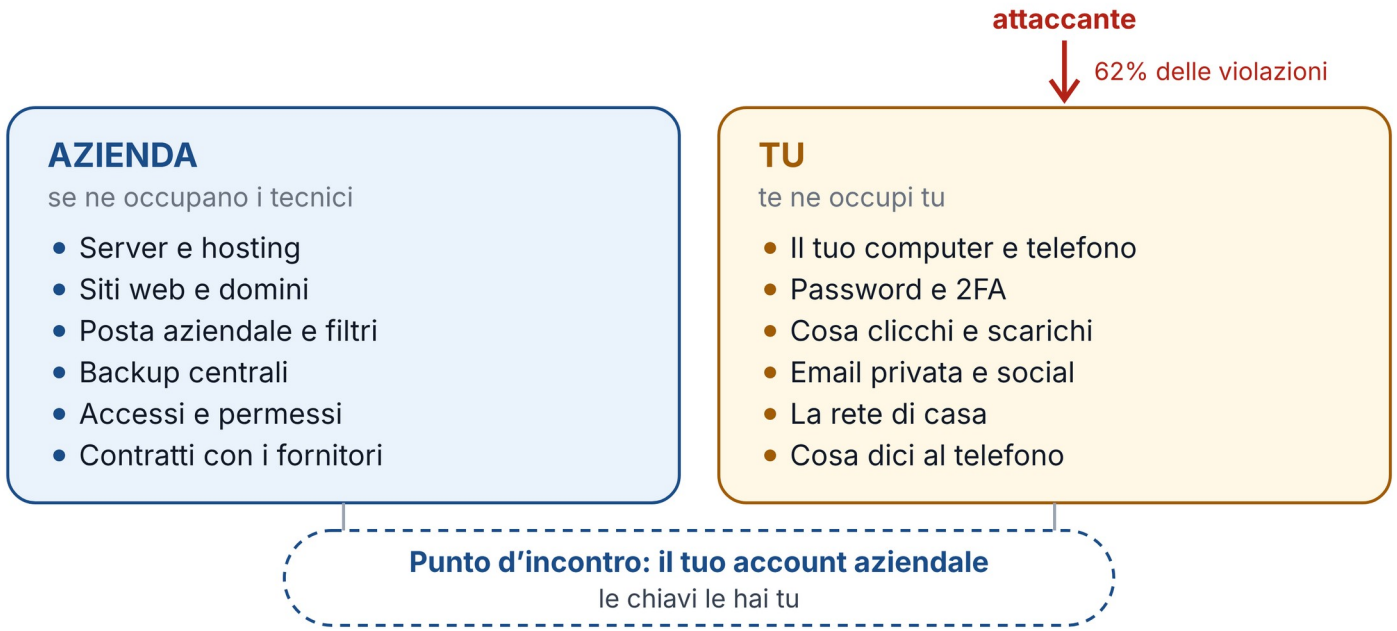
Con una regola chiara non improvvisi: se qualcuno ti mette fretta, la risposta è già scritta.

2 persone

firmano ogni pagamento. Se la richiesta è nuova, urgente o insolita, prima si richiama a un numero già noto

La regola dei 4 occhi

L’azienda ha due perimetri. Uno sei tu



Schema dal capitolo 1: “Perché riguarda te”

48% · ransomware

Quasi una violazione su due coinvolge un ransomware: file bloccati o rubati e un riscatto (Verizon DBIR 2026).

48% · fornitori

Quasi una su due passa da un fornitore o un partner, in forte aumento (Verizon DBIR 2026).

UN CASO VERO

Una videochiamata da 25 milioni

GENNAIO 2024, HONG KONG

Un dipendente di Arup riceve un messaggio che sembra del direttore finanziario: serve un’operazione riservata.

LA VIDEOCHIAMATA

Sospetta, ma in video vede il direttore e alcuni colleghi. Facce e voci giuste. Sono tutti falsi, creati con l’AI.

IL RISULTATO

15 bonifici su 5 conti: 200 milioni di dollari di Hong Kong, circa 25 milioni di dollari americani.

Cosa l’avrebbe fermato

Richiamare il direttore a un numero già noto e far approvare il pagamento da una seconda persona. È la regola dei 4 occhi.

Nel materiale

La regola dei 4 occhi passo per passo: capitolo 3. Se un pagamento è già partito: playbook nel capitolo 9.

Fonti: CNN, 16.05.2024 · Dezeen, 17.05.2024

UNA REGOLA CHIAVE

Ogni dato ha un livello

Pubblico

Fatto per essere visto da tutti

Esempi: sito web, brochure, annunci pubblicati

Interno

Per i colleghi, danno limitato se esce

Esempi: procedure, organigramma, calendario interno

Confidenziale

Solo per chi ne ha bisogno, per nome

Esempi: contratti, offerte, dati clienti, finanze

Segreto

Accesso minimo, sempre cifrato

Esempi: credenziali, dati bancari, documenti d’identità, salute

Il livello decide dove può andare. Email, Drive, WhatsApp, AI, chiavetta: la tabella completa è nel capitolo sui dati. Nel dubbio, Confidenziale.

SE SUCCEDE

Quattro passi, in quest'ordine

1

Stop

Non cliccare altro, non cancellare niente.

2

Stacca dalla rete

Wi-Fi spento, cavo scollegato.

3

Non spegnere

La memoria contiene le prove di cosa è stato preso.

4

Segnala

Al referente IT: cosa, quando, foto dello schermo con il telefono.

Unica eccezione: file che cambiano nome sotto i tuoi occhi. Stacca la rete e, se continua, spegni.

Nel materiale, capitolo 9: 8 playbook, uno per ogni caso: link cliccato, account rubato, pagamento partito, telefono perso e altri.

IL MATERIALE

Cosa trovi nella Parte 2

SEZIONE A

Regole

1 Perché riguarda te
2 Account, password e 2FA: le regole
3 Email, telefono e pagamenti: le regole
4 Dispositivi, casa e viaggio
5 Dati: classificazione e condivisione
6 Ufficio e sicurezza fisica
7 Software, social e AI
8 Privacy e legge (nLPD)

SEZIONE B

Processi e setup

9 Incidenti: cosa fare
10 Setup guidato
11 Entrata, cambio ruolo, uscita

SEZIONE C

Policy e verifica

12 Le 12 policy in breve
13 Tech stack aziendale
14 Checklist obbligatoria
15 Test
16 Fonti e approfondimenti

Obbligatorio per tutti: checklist da 20 punti, test da 10 domande e le 12 policy.

ADESSO, INSIEME

Tre cose da fare in 10 minuti

10 minuti

1

Salva nel telefono nome e numero del referente IT

Quello della tua azienda. Se non risponde entro 15 minuti, chiami la direzione.

2

Fai tua la regola della richiamata

Richiesta nuova, urgente o insolita di soldi, dati o accessi? Richiami tu, a un numero che avevi già.

3

Classifica un documento che hai usato oggi

Pubblico, Interno, Confidenziale o Segreto? Nel dubbio, Confidenziale.

DOPO L’INCONTRO

Il resto lo leggi con calma

COME SI USA IL MATERIALE

- Apri il link nel browser, anche dal telefono
- Italiano o inglese: interruttore in alto a destra
- Capitoli nel menu a sinistra, ognuno con il riassunto in cima
- La checklist si salva da sola sul tuo dispositivo

IL TUO PROGRAMMA

Entro una settimana

Leggi la Parte 2. Circa 45 minuti.

Entro tre settimane

Setup guidato dei dispositivi con il referente IT. Circa 2-3 ore.

Poi

Checklist da 20 punti, test e le 12 policy. Dopo, AI Parte 1: AI al lavoro.

PER CHIUDERE

Domande?

DA PORTARE A CASA

- ✓ Soldi, dati o accessi: mai su richiesta arrivata da un solo canale
- ✓ Ogni dato ha un livello. Nel dubbio, Confidenziale
- ✓ Se succede: stop, stacca, non spegnere, segnala

Se ti succede qualcosa: avvisa subito il referente IT della tua azienda. Prima lo fai, meglio è. Senza vergogna.

FONTI

Da dove vengono i dati

Verizon DBIR 2026
48% ransomware, 48% fornitori, 62% fattore umano
verizon.com

nLPD, Legge federale sulla protezione dei dati
multa fino a CHF 250’000 alla persona, art. 60 ss.
fedlex.admin.ch

CNN, 16.05.2024
Arup, 25 milioni di dollari persi con un deepfake
cnn.com

Dezeen, 17.05.2024
15 bonifici su cinque conti, gennaio 2024
dezeen.com

Tutte le fonti, con i link, sono anche nell’ultimo capitolo del materiale.

© 2026 Aron Clementi. Materiale formativo a scopo informativo: non sostituisce una consulenza legale o tecnica né le regole della tua azienda. Fonti verificate alla data indicata; strumenti e prezzi cambiano.